

PS03 – Plan de Continuidad del Negocio y Recuperacion de Desastres

ID Documento: GOYA-PS03-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Revision operacional	Administrador Sistemas	Administrador de Infraestructura
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye exclusivamente al Comité de Crisis, Oficial de Seguridad, Administrador de Sistemas, Arquitecto de Sistema, Administrador PKI, Oficial de RA, y personal con responsabilidades directas en la operacion de los servicios de confianza del PSC. Cada receptor debe registrar acuse de recibo.

1.3 Relacion con EA-103 v2.1

Este plan cumple con el sub-proceso PS03 de la Guia de Acreditacion EA-103 v2.1 de la Entidad Acreditadora (Subsecretaria de Economia), y satisface los seis criterios de evaluacion de la seccion 4.10:

Criterio EA-103	Referencia en este documento
Requisitos de continuidad ISO 27002 incorporados	Secciones 3, 5, 6
Procedimiento de revision y evaluacion periodica	Seccion 10
Procedimientos de compromiso de llave conforme ETSI TS 102 042 S7.4.8	Seccion 6.3
Plan coherente con niveles de riesgo de PS01	Seccion 11
Analisis de Impacto al Negocio (BIA) incluido	Seccion 4
Instalaciones alternativas cumplen requisitos del servicio	Seccion 8

1.4 Documentos relacionados

Documento	ID	Relacion
Plan de Gestion de Riesgos y Amenazas	GOYA-PS01-001	Entrada: niveles de riesgo y registro de riesgos
Politica de Seguridad de la Informacion	GOYA-PS02-001	Dependencia: PS03 requiere PS02 satisfecho
Certification Practice Statement	GOYA-CPS-001	Referencia: politicas de revocacion y ciclo de vida
Plan de Respuesta a Incidentes	GOYA-IRP-001	Complemento: escalacion de incidentes a crisis

2. Objetivo y Alcance

2.1 Objetivo

Establecer los procedimientos, estrategias y recursos necesarios para garantizar la continuidad operativa de los servicios de confianza de Goya Ledger SpA como Prestador de Servicios de Certificacion (PSC) bajo la Ley 19.799 y DS 181/2002, y la recuperacion oportuna ante eventos disruptivos. Este plan asegura que los

servicios criticos del PSC se restablezcan dentro de los objetivos de tiempo definidos, minimizando el impacto sobre suscriptores, partes confiantes y la validez juridica de los documentos electronicos emitidos.

2.2 Alcance

El alcance cubre la totalidad de los servicios de confianza del PSC y su infraestructura de soporte:

Servicio	Descripcion	Criticidad
Respondedor OSCP	Consultas de estado de certificados en tiempo real (RFC 6960)	Critica
Publicacion CRL	Listas de revocacion de certificados	Critica
API Gateway	Punto de acceso unificado a todos los servicios	Critica
Autoridad de Sellado de Tiempo (TSA)	Sellos de tiempo RFC 3161 con precision NTP verificada	Alta
Registro de Auditoria	Cadena de hash SHA-256, append-only, en RocksDB	Alta
Autoridad Certificadora (CA)	Emision de certificados X.509 FEA con ML-DSA-65 (FIPS 204)	Alta
Autoridad de Registro (RA)	Verificacion de identidad presencial y remota (Smart-ID, ClaveUnica)	Media

2.3 Relacion con PS01 y PS02

Este plan se construye sobre los resultados del analisis de riesgos de PS01 (GOYA-PS01-001). Los escenarios de emergencia de la seccion 6 corresponden directamente a los riesgos identificados en el registro de riesgos de PS01 seccion 6. Los objetivos de recuperacion (RTO/RPO) se justifican por los niveles de riesgo y el impacto determinado en el BIA (seccion 4).

La Politica de Seguridad PS02 (GOYA-PS02-001) establece los controles preventivos. PS03 define los procedimientos reactivos cuando dichos controles fallan o un evento disruptivo supera las capacidades de prevencion.

3. Marco Normativo

3.1 Normas y estándares aplicables

Norma	Aplicacion en este documento
ISO 22301:2019	Sistema de gestion de continuidad del negocio: estructura BIA, estrategias, planes, ejercicios
ISO/IEC 27002:2022 A.5.29	Seguridad de la informacion durante disrupcion
ISO/IEC 27002:2022 A.5.30	Preparacion de TIC para la continuidad del negocio
ISO/IEC 27002:2022 A.8.13	Respaldo de la informacion
ISO/IEC 27002:2022 A.8.14	Redundancia de instalaciones de procesamiento de informacion
ETSI TS 102 042 S7.4.8	Procedimientos de compromiso de clave de CA
ETSI EN 319 401 S7.12	Continuidad del negocio para prestadores de servicios de confianza
Ley 19.799 Art. 17	Obligaciones del PSC respecto a disponibilidad del servicio
Ley 19.799 Art. 5	Admisibilidad probatoria del documento electronico
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma tecnica para FEA
Ley 21.459	Delitos informaticos (notificacion ante incidentes)

3.2 Controles ISO 27002:2022 implementados

Control	Descripcion	Seccion de este documento
A.5.29	Seguridad de la informacion durante disrupcion	Secciones 5, 6
A.5.30	Preparacion de TIC para la continuidad del negocio	Secciones 4, 5, 8
A.8.13	Respaldo de la informacion	Seccion 5.2

Control	Descripcion	Seccion de este documento
A.8.14	Redundancia de instalaciones de procesamiento de informacion	Secciones 5.1, 8

4. Analisis de Impacto al Negocio (BIA)

4.1 Metodologia

El BIA se realiza siguiendo ISO 22301:2019 clausula 8.2.2 con la siguiente metodologia:

1. Identificacion de servicios y procesos criticos del PSC.
2. Determinacion de las consecuencias de interrupcion en cuatro dimensiones (financiero, reputacional, legal, operacional).
3. Establecimiento de plazos maximos tolerables de interrupcion (MTPD).
4. Derivacion de objetivos de recuperacion (RTO y RPO) a partir del MTPD.
5. Identificacion de dependencias internas y externas.
6. Priorizacion de la recuperacion segun criticidad.

4.2 Evaluacion de impacto por servicio

Servicio	Impacto financiero	Impacto reputacional	Impacto legal	Impacto operacional	Clasificacion
Respondedor OSCP	Alto: partes confiantes no pueden validar certificados; transacciones FEA se detienen	Critico: perdida de confianza inmediata de suscriptores y partes confiantes	Critico: DS 181 exige disponibilidad de informacion de estado	Critico: todas las verificaciones de firma dependen de OSCP	Critica
Publicacion CRL	Alto: respaldo de OSCP; sin CRL la revocacion no se propaga	Alto: suscriptores perciben servicio degradado	Critico: DS 181 requiere publicacion oportuna de revocacion	Alto: mecanismo de fallback para validacion offline	Critica
API Gateway	Alto: punto unico de acceso a servicios; sin API ningun suscriptor opera	Alto: percepcion de caida total del servicio	Medio: no hay obligacion especifica sobre tiempo de respuesta API	Critico: todos los servicios se consumen via API	Critica
TSA					Alta

Servicio	Impacto financiero	Impacto reputacional	Impacto legal	Impacto operacional	Clasificacion
Registro de auditoria	Medio: sellos de tiempo no urgentes pueden encolarse	Alto: confianza en la precision temporal del PSC	Alto: Ley 19.799 Art. 5 reconoce sellos como prueba de fecha cierta	Alto: monotonicia de seriales debe preservarse	Alta
	Bajo: no genera ingresos directos	Alto: cuestionamiento de integridad del PSC	Critico: DS 181 exige registros de todas las operaciones; evidencia judicial	Alto: prerequisite para cualquier investigacion o auditoria	
CA (emision)	Medio: nuevas emisiones pueden esperar si revocacion funciona	Medio: retraso perceptible pero no critico si OCSP/CRL operan	Medio: no hay obligacion de emision inmediata	Medio: proceso batch, cola de solicitudes	Alta
RA (verificacion)	Bajo: proceso humano con cola inherente	Bajo: suscriptores comprenden tiempos de verificacion	Bajo: sin obligacion de inmediatez en proofing	Bajo: independiente de otros servicios	Media

4.3 Objetivos de recuperacion

Servicio	RTO	RPO	MTPD	Justificacion
Respondedor OCSP	15 min	0 (sin estado)	1 hora	Validacion de certificados no debe detenerse; partes confiantes consultan OCSP en cada verificacion de firma
Publicacion CRL	1 hora	Ultima CRL publicada	4 horas	DS 181 requiere informacion de revocacion oportuna; CRL es respaldo de OCSP
API Gateway	15 min	N/A (sin estado)	1 hora	Punto de acceso unico a todos los servicios del PSC
TSA	4 horas	Ultimo serial emitido	12 horas	Monotonicia de serial critica; precision NTP debe verificarse antes de reanudar
Registro de auditoria	4 horas	0 (cadena de hash)	8 horas	Cadena de hash append-only no tolera gaps; integridad probatoria

Servicio	RTO	RPO	MTPD	Justificacion
CA (emision)	24 horas	Ultimo certificado emitido	48 horas	Nuevas emisiones pueden encolarse; revocacion e informacion de estado tienen prioridad
RA (verificacion)	48 horas	Ultimo registro de proofing	72 horas	Proceso humano; solicitudes se encolan sin perdida

4.4 Mapa de dependencias

4.4.1 Dependencias internas

Servicio	Depende de	Tipo de dependencia
OCSP	CA (certificado de firma OCSP), RocksDB (estado de revocacion)	Datos y clave
CRL	CA (clave de firma CRL), RocksDB (lista de revocacion)	Datos y clave
TSA	NTP (precision temporal), RocksDB (serial counter), CA (certificado TSA)	Tiempo, datos, clave
CA	RocksDB (seriales, estado), Clave privada CA intermedia, Consenso BFT	Datos, clave, infraestructura
Registro de auditoria	RocksDB (WAL + checkpoints), Cadena de hash SHA-256	Almacenamiento
API Gateway	Todos los servicios backend, TLS (certificado de servidor)	Servicio, clave
RA	Smart-ID / ClaveUnica (verificacion de identidad), CA (emision)	Servicio externo

4.4.2 Dependencias externas

Proveedor	Servicio que provee	Impacto si falla	Mitigacion
Fly.io	Infraestructura de computo y red (region IAD)	Todos los servicios caen si la region completa falla	Multi-region deployment, failover automatico
NTP pools (pool.ntp.org)	Sincronizacion temporal para TSA	TSA no puede emitir sellos con precision verificable	Multiples fuentes NTP, drift detection, suspension automatica de TSA si drift > 1s
Smart-ID / SK ID Solutions	Verificacion de identidad remota (eID Estonia)	RA no puede verificar identidades remotas	Fallback a verificacion presencial; cola de solicitudes
ClaveUnica / ChileAtiende	Verificacion de identidad chilena	RA limitada a verificacion presencial	Cola de solicitudes, verificacion manual
DNS providers	Resolucion de nombres para API y OCSP	Clientes no pueden resolver endpoints	DNS redundante, TTL bajo, fallback por IP directa

4.5 Procesos criticos identificados

Proceso	Servicios involucrados	Prioridad de recuperacion
Validacion de estado de certificado	OCSP, CRL, API Gateway	1 (inmediata)
Emision de sellos de tiempo	TSA, API Gateway, NTP	2 (alta)
Integridad del registro de auditoria	Registro de auditoria, RocksDB	2 (alta)
Emision de certificados	CA, RA, Consenso BFT, API Gateway	3 (media)
Verificacion de identidad	RA, Smart-ID/ClaveUnica	4 (baja)

5. Estrategia de Continuidad

5.1 Redundancia de infraestructura

5.1.1 Topologia multi-nodo BFT

La infraestructura de produccion opera con cuatro nodos BFT (HotStuff + DPoS) en Fly.io:

Nodo	Identificador	Region	Rol
Nodo 1	goya-node	IAD (Ashburn, Virginia)	Primario / Lider BFT
Nodo 2	goya-node-2	IAD	Replica BFT
Nodo 3	goya-node-3	IAD	Replica BFT
Nodo 4	goya-node-4	IAD	Replica BFT

El consenso BFT tolera hasta f nodos bizantinos en una red de $3f+1$ nodos. Con 4 nodos, el sistema tolera 1 nodo bizantino o caido sin interrupcion del consenso.

La replicacion del estado blockchain se realiza automaticamente via el protocolo de consenso. Cada nodo mantiene una copia completa del estado en RocksDB.

5.1.2 Distribucion geografica

Sitio	Rol	Servicios	Control ISO 27002
Primario (IAD, Fly.io)	Activo	Todos los servicios del PSC	A.8.14
Secundario (pendiente activacion)	Standby caliente	OCSF, CRL mirror, API read-only	A.8.14
Bodega offline	Almacenamiento frio	Fragmentos de clave raiz CA, medios de respaldo cifrados	A.8.13

El sitio secundario se activara en una region Fly.io alternativa (ORD o SJC) como parte de la hoja de ruta de expansion. Mientras tanto, la redundancia intra-region con 4 nodos BFT proporciona tolerancia a fallos de nodo individual.

5.2 Estrategia de respaldo de datos

Dato	Metodo	Frecuencia	Retencion	Ubicacion	Control ISO 27002
Estado RocksDB	Checkpoint snapshot (src/checkpoint.rs,	Cada 1000 bloques o 1 hora (lo	30 dias	Primario + secundario	A.8.13

Dato	Metodo	Frecuencia	Retencion	Ubicacion	Control ISO 27002
	src/storage/snapshot.rs)	que ocurra primero)			
Registros de auditoria	Exportacion con verificacion de hash + cifrado	Diario	7 anos	Almacenamiento off-site cifrado	A.8.13, A.5.33
Fragmentos de clave CA	Ceremonia de custodia M-of-N	Al generar	Permanente	Instalaciones seguras separadas	A.8.24
Configuracion	Repositorio Git	Al cambiar	Permanente	Repositorio remoto	A.8.13
Estado serial TSA	Persistencia atomica por token	Por token emitido	7 anos	Con registros de auditoria	A.8.13
Estado de consenso BFT	WAL de Raft + persistencia de log	Continuo	30 dias	Cada nodo BFT	A.8.13

Los respaldos se verifican mediante restauracion automatizada mensual en entorno de prueba (seccion 9).

5.3 Respaldo y recuperacion de claves

5.3.1 Ceremonia M-of-N para clave raiz CA

La clave raiz CA se protege mediante esquema de secreto compartido M-of-N (Shamir's Secret Sharing):

- **N**: numero total de fragmentos distribuidos a custodios.
- **M**: minimo de fragmentos requeridos para reconstruccion ($M < N$).
- Los valores especificos de M y N se definen en la ceremonia de clave documentada en el CPS (GOYA-CPS-001).

Procedimiento de recuperacion:

1. El Comite de Crisis autoriza la reconstruccion por unanimidad.
2. Se convoca a M custodios a instalacion segura con control de acceso fisico.
3. Cada custodio aporta su fragmento en presencia de testigo notarial.
4. Se reconstruye la clave en HSM/dispositivo criptografico aislado (air-gapped).
5. Se verifica la clave reconstruida contra el hash publico conocido.
6. Se ejecuta la operacion requerida (emision de intermedia, revocacion).
7. La clave reconstruida se destruye del dispositivo temporal; los fragmentos se devuelven a los custodios.
8. Se registra acta de ceremonia en el registro de auditoria.

5.3.2 Clave intermedia CA

La clave intermedia CA se respalda cifrada en la bóveda offline. La recuperación requiere:

1. Autorización del Comité de Crisis.
2. Acceso a la bóveda con doble custodia.
3. Desciframiento con clave de protección (almacenada por separado).
4. Carga en el nodo primario en memoria protegida.
5. Verificación: emisión de certificado de prueba y validación OCSP.

5.4 Plan de comunicación durante crisis

5.4.1 Notificaciones internas

Nivel de crisis	Tiempo de notificación	Canal	Destinatarios
Alerta (degradación menor)	30 minutos	Email + mensajería interna	Administrador Sistemas, Líder Desarrollo
Crisis (servicio crítico caído)	15 minutos	Teléfono + mensajería interna	Comité de Crisis completo
Emergencia (compromiso de clave, desastre)	Inmediata	Teléfono	Gerente General, Oficial de Seguridad, Administrador PKI

5.4.2 Notificaciones externas

Destinatario	Evento	Plazo	Canal	Requisito legal
Suscriptores y partes confiantes	Indisponibilidad de servicio > RTO	1 hora tras superar RTO	Página de estado, email	Ley 19.799 Art. 17
Subsecretaría de Economía (Entidad Acreditadora)	Compromiso de clave, brecha de seguridad	24 horas	Canal oficial definido por EA	EA-103 v2.1
CSIRT Chile	Incidente de ciberseguridad	3 horas	Plataforma CSIRT	Ley 21.459
Suscriptores afectados	Revocación masiva por compromiso de clave	Inmediata tras decisión de revocación	Email directo + página de estado	DS 181, CPS

5.5 Roles y responsabilidades – Comité de Crisis

Rol	Responsabilidad	Titular
Director de Crisis	Decisiones estrategicas, autorizacion de escalacion, comunicacion con EA	Gerente General
Coordinador de Crisis	Coordinacion operativa, ejecucion del plan, registro de acciones	Oficial de Seguridad
Lider Tecnico	Diagnostico, ejecucion de procedimientos de recuperacion, verificacion	Arquitecto de Sistema
Operador de Infraestructura	Restauracion de nodos, failover, respaldos	Administrador Sistemas
Operador PKI	Operaciones de CA, revocacion, emision de emergencia	Administrador PKI
Comunicaciones	Notificaciones a suscriptores, EA, CSIRT	Oficial de Seguridad

La activacion del Comité de Crisis ocurre cuando:

- Un servicio critico supera su RTO.
- Se detecta o sospecha compromiso de clave privada.
- Falla simultanea de 2 o mas nodos BFT.
- Evento de seguridad que requiere notificacion a la EA.

6. Escenarios de Emergencia

6.1 Desastre de software que afecta servicios del PSC

Referencia PS01: R-18 (despliegue de codigo con errores), R-32 (bug en logica de consenso o firma).

6.1.1 Descripcion y disparadores

Despliegue de actualizacion de software que introduce un defecto critico que afecta la operacion de uno o mas servicios del PSC. Incluye: regresion en logica de firma, error en validacion de certificados, corrupcion de estado por migracion fallida, incompatibilidad entre versiones de nodos BFT.

Disparadores:

- Error en validacion de firma FEA/FES tras despliegue.
- Emision de certificados con campos incorrectos.
- Fallo de consenso BFT por incompatibilidad de protocolo entre nodos.
- Respuestas OSCP incorrectas o TSA con sellos invalidos.

6.1.2 Deteccion

- Monitores de salud de API (/api/v1/health) reportan fallo.

- Test de integridad post-despliegue falla (certificado de prueba, sello de prueba, verificación OSCP).
- Alertas de Fly.io por reinicio continuo de máquinas.
- Reporte de suscriptor o parte confiante sobre respuesta incorrecta.

6.1.3 Procedimiento de respuesta

1. El Administrador Sistemas detecta el fallo y lo clasifica como desastre de software.
2. Suspensión inmediata del despliegue a nodos restantes (si es rolling deploy).
3. Identificación de la versión afectada y los nodos que la ejecutan.
4. Rollback inmediato a la versión anterior en los nodos afectados: `fly deploy --image <version_anterior>`.
5. Verificación de que los nodos con rollback responden correctamente.

6.1.4 Procedimiento de recuperación

1. Verificar integridad del estado en RocksDB: `verify_audit_chain()`.
2. Si el estado está corrupto, restaurar desde el último checkpoint válido.
3. Sincronizar estado desde nodos no afectados vía protocolo BFT.
4. Ejecutar suite de verificación completa: emisión de certificado de prueba, sello TSA de prueba, consulta OSCP, verificación de cadena de hash de auditoría.
5. Verificar monotonía de serial TSA.

6.1.5 Verificación y retorno a operación normal

- Todos los endpoints de API responden 200 en health check.
- `verify_audit_chain()` pasa sin errores.
- Certificado de prueba se emite y valida correctamente.
- Sello TSA con serial mayor al último conocido.
- NTP sync validado (`NtpTimeSource::validate()`).
- Consenso BFT opera con todos los nodos.

RTO: 4 horas. **RPO:** Último checkpoint válido.

6.2 Incidente de seguridad que afecta operación del sistema

Referencia PS01: R-03 (intrusión a nodos BFT), R-04 (DDoS contra API Gateway), R-14 (phishing contra operador PKI), R-26 (exfiltración de datos).

6.2.1 Descripción y disparadores

Evento de seguridad que compromete la integridad, confidencialidad o disponibilidad de los sistemas del PSC. Incluye: intrusión a nodos, DDoS, acceso no autorizado por credenciales comprometidas, exfiltración de datos, malware/ransomware.

Disparadores:

- Alerta de detección de intrusión (acceso anómalo a nodos BFT).
- Volumetría de tráfico anómala en API Gateway (indicador de DDoS).
- Acceso administrativo desde IP o credencial no reconocida.

- Deteccion de proceso no autorizado en nodo de produccion.
- Cifrado no autorizado de archivos (ransomware).

6.2.2 Deteccion

- Logs estructurados (JSON) en cada nodo con correlacion de trace ID.
- Alertas de rate limiting (RATE_LIMIT_RPS/RPM/RPH) excedido.
- Monitoreo de acceso administrativo via ACL (ACL_MODE).
- Verificacion periodica de integridad de binarios desplegados.

6.2.3 Procedimiento de respuesta

1. Coordinador de Crisis activa el Comite de Crisis.
2. Aislamiento del componente afectado:
 - DDoS: activacion de mitigacion en Fly.io, restriccion de origenes CORS.
 - Intrusion: aislamiento de red del nodo comprometido, revocacion de credenciales afectadas.
 - Ransomware: desconexion inmediata del nodo, preservacion de evidencia.
3. Evaluacion del alcance: determinar si la integridad de claves privadas, estado de certificados o registros de auditoria se vio afectada.
4. Si existe sospecha de compromiso de clave privada, escalar a seccion 6.3.
5. Notificacion a CSIRT Chile dentro de 3 horas (Ley 21.459).
6. Preservacion de evidencia segun seccion 7.

6.2.4 Procedimiento de recuperacion

1. Reconstruccion del nodo desde imagen limpia de sistema operativo.
2. Restauracion del estado desde nodo BFT no comprometido o checkpoint.
3. Rotacion de todas las credenciales de acceso administrativo.
4. Verificacion de integridad de cadena de auditoria: `verify_audit_chain()`.
5. Verificacion de que ningun certificado fue emitido durante la ventana de compromiso sin autorizacion. En caso positivo, revocacion inmediata de los certificados afectados.
6. Restablecimiento de servicios en orden de prioridad (seccion 5.1).

6.2.5 Verificacion y retorno a operacion normal

- Todos los nodos ejecutan imagen verificada.
- Credenciales rotadas y acceso validado.
- Cadena de auditoria integra y sin gaps.
- No existen certificados emitidos sin autorizacion en la ventana de incidente.
- Monitoreo reforzado durante 72 horas post-incidente.
- Informe post-incidente completado y remitido a la EA si aplica.

RTO: Variable segun alcance. DDoS: 1 hora. Intrusion con reconstruccion: 4-24 horas. **RPO:** 0 (estado replicado en nodos no comprometidos).

6.3 Compromiso de llave privada de firma (ETSI TS 102 042 S7.4.8)

Referencia PS01: R-01 (robo de clave raiz CA), R-02 (robo de clave intermedia CA).

Este escenario implementa los requisitos de ETSI TS 102 042 S7.4.8 para procedimientos de compromiso o sospecha de compromiso de la clave privada de la CA.

6.3.1 Descripcion y disparadores

Compromiso confirmado o sospechado de una clave privada utilizada para firmar certificados, CRLs, respuestas OCSP o sellos de tiempo. Constituye el escenario de mayor severidad para un PSC.

Disparadores:

- Evidencia de uso no autorizado de la clave (firma sobre datos no solicitados).
- Deteccion de exfiltracion de material criptografico.
- Acceso fisico no autorizado a dispositivo que almacena la clave.
- Compromiso de custodia M-of-N (perdida o robo de M o mas fragmentos).
- Vulnerabilidad criptografica publicada que afecta el algoritmo en uso.

6.3.2 Deteccion

- Registros de auditoria muestran operaciones de firma no correlacionadas con solicitudes legítimas.
- Alerta de custodia: un custodio reporta perdida o robo de su fragmento.
- Publicacion de CVE que afecta ML-DSA-65 o Ed25519.
- Verificacion criptografica de firmas revela firma con clave presuntamente inactiva.

6.3.3 Procedimiento de respuesta

Conforme ETSI TS 102 042 S7.4.8:

1. Confirmacion y clasificacion:

- Determinar si el compromiso es confirmado o sospechado.
- Identificar la clave afectada: raiz CA, intermedia CA, firma OCSP, firma TSA.
- Registrar hora exacta de deteccion y ventana estimada de compromiso.

2. Contencion inmediata:

- Desactivar la clave comprometida en todos los nodos.
- Detener la emision de certificados, CRLs y sellos firmados con la clave afectada.
- Si la clave intermedia esta comprometida, mantener OCSP y CRL operativos con la clave de la CA raiz (si no esta comprometida).

3. Notificaciones obligatorias:

- Notificacion a la Entidad Acreditadora (Subsecretaria de Economia) dentro de 24 horas.
- Notificacion a todos los suscriptores cuyos certificados fueron firmados con la clave comprometida.
- Notificacion a partes confiantes mediante publicacion de aviso en pagina de estado.
- Notificacion a CSIRT Chile si el compromiso resulta de un incidente de seguridad.

4. Revocacion:

- Revocar el certificado de la CA cuya clave fue comprometida.

- Publicar CRL de emergencia firmada con la clave de nivel superior (raíz si la intermedia fue comprometida).
- Actualizar respuestas OSCP para reflejar el estado de revocación.

5. Evaluación de impacto:

- Identificar todos los certificados emitidos durante la ventana de compromiso.
- Determinar si alguno fue emitido fraudulentamente.
- Revocar los certificados emitidos fraudulentamente.
- Evaluar si los certificados emitidos legítimamente durante la ventana requieren re-emisión.

6.3.4 Procedimiento de recuperación

1. Generación de nueva clave:

- Ejecutar ceremonia de generación de nueva clave CA en dispositivo criptográfico aislado.
- Si la clave raíz está comprometida: generar nueva clave raíz y nueva jerarquía completa.
- Si la clave intermedia está comprometida: generar nueva clave intermedia firmada por la raíz.
- Distribuir nuevos fragmentos M-of-N a custodios (con custodios distintos si el compromiso fue por custodia).

2. Re-emisión:

- Emitir nuevo certificado de CA intermedia.
- Re-emitar certificados de suscriptores afectados con nueva clave. Notificar a cada suscriptor individualmente.
- Emitir nuevo certificado de firma OSCP y TSA si es necesario.

3. Publicación:

- Publicar nueva CRL firmada con la nueva clave.
- Actualizar el repositorio de certificados de CA.
- Actualizar el CPS si la política cambió como resultado del incidente.

6.3.5 Verificación y retorno a operación normal

- Todos los servicios operan con la nueva clave.
- CRL de emergencia publicada y accesible.
- OSCP responde correctamente con la nueva clave de firma.
- Todos los suscriptores notificados y certificados re-emitidos.
- Informe completo de compromiso remitido a la EA con: cronología, alcance, acciones tomadas, medidas preventivas.
- Revisión del CPS y PS01 para incorporar lecciones aprendidas.
- Revisión de la ceremonia de custodia M-of-N si el compromiso fue por custodia.

RTO: 24 horas (contención y revocación). Re-emisión completa: 72 horas. **RPO:** N/A (evento de clave, no de datos).

6.4 Falla del mecanismo de auditoría

Referencia PS01: R-19 (eliminación accidental de registros de auditoría), R-16 (corrupción de RocksDB).

6.4.1 Descripción y disparadores

Falla en el sistema de registro de auditoría que compromete la capacidad del PSC de mantener registros de todas las operaciones conforme DS 181/2002. La cadena de hash SHA-256 append-only es la evidencia probatoria del PSC ante tribunales.

Disparadores:

- `verify_audit_chain()` retorna error de integridad.
- Gap detectado en la secuencia de registros de auditoría.
- RocksDB WAL corrupto o inaccesible.
- Espacio de almacenamiento agotado que impide nuevos registros.
- Eliminación accidental o maliciosa de registros.

6.4.2 Detección

- Verificación semanal automatizada de cadena de hash:
`verify_audit_chain()`.
- Monitoreo de espacio de almacenamiento (R-30 en PS01): alerta al 80% de capacidad.
- Alertas de RocksDB por errores de escritura en WAL.
- Fallo en la exportación diaria de registros de auditoría a almacenamiento off-site.

6.4.3 Procedimiento de respuesta

1. Evaluación inmediata del alcance:

- Ejecutar `verify_audit_chain()` para identificar el punto exacto de falla.
- Determinar si la falla es de integridad (hash roto) o de disponibilidad (almacenamiento inaccesible).
- Identificar la ventana temporal sin registros o con registros comprometidos.

2. Suspensión condicional de servicios:

- Si la auditoría no puede registrar operaciones: suspender emisión de certificados y sellos de tiempo hasta restaurar el mecanismo.
- OSCP puede continuar operando (no genera registros transaccionales nuevos, solo consultas).
- Registrar manualmente las operaciones críticas que no pudieron escribirse automáticamente.

3. Contención:

- Si es por almacenamiento: expansión inmediata de volumen o purga de datos no críticos.
- Si es por corrupción: aislar el volumen corrupto para análisis forense.
- Activar mecanismo de auditoría alternativo (log a archivo temporal) mientras se restaura el primario.

6.4.4 Procedimiento de recuperación

1. Identificar el último registro válido en la cadena de hash.
2. Restaurar el estado de auditoría desde:
 - Exportación diaria off-site (si es posterior al último registro válido), o
 - Checkpoint de RocksDB del nodo afectado, o
 - Estado de auditoría de otro nodo BFT (replicas mantienen cadena idéntica).
3. Reconstruir la cadena de hash desde el punto de restauración.

4. Si existen operaciones no registradas durante la ventana de falla, reconstruirlas desde los logs de aplicacion de los nodos.
5. Verificar integridad completa: `verify_audit_chain()` desde el genesis hasta el ultimo registro.
6. Reanudar la exportacion diaria a almacenamiento off-site.

6.4.5 Verificacion y retorno a operacion normal

- `verify_audit_chain()` pasa desde el genesis hasta el registro mas reciente.
- No existen gaps en la secuencia de registros.
- La exportacion diaria a almacenamiento off-site opera normalmente.
- Almacenamiento disponible > 50% de capacidad.
- Servicios suspendidos se reanudan en orden de prioridad.

RTO: 4 horas. **RPO:** 0 (cadena de hash no tolera gaps).

6.5 Falla de hardware (servidores, dispositivos criptograficos, dispositivos de red)

Referencia PS01: R-21 (terremoto en datacenter), R-22 (incendio), R-30 (agotamiento de almacenamiento), R-31 (corte electrico prolongado).

6.5.1 Descripcion y disparadores

Falla fisica de uno o mas componentes de la infraestructura que soporta los servicios del PSC. En el contexto de Goya Ledger sobre Fly.io, la infraestructura fisica es gestionada por el proveedor cloud; sin embargo, las fallas de las maquinas virtuales tienen el mismo efecto operativo.

Disparadores:

- Maquina Fly.io no responde a health checks.
- Disco persistente (volumen Fly.io) corrupto o inaccesible.
- Fallo de conectividad de red entre nodos BFT.
- Fallo de dispositivo criptografico (HSM o equivalente software).

6.5.2 Deteccion

- Health checks de Fly.io (intervalo < 30 segundos).
- Consenso BFT detecta nodo ausente (timeout de heartbeat).
- Monitoreo de latencia P2P entre nodos.
- Alertas de Fly.io por estado de maquina.

6.5.3 Procedimiento de respuesta

Falla de nodo individual (1 de 4):

1. El consenso BFT continua operando con 3 nodos restantes (tolerancia bizantina intacta con $3f+1=4$, $f=1$).
2. Fly.io recrea automaticamente la maquina en hardware disponible.
3. Si la recreacion automatica falla, el Administrador Sistemas recrea manualmente: `fly machine restart` o `fly deploy`.

4. El nuevo nodo sincroniza estado desde los peers via protocolo BFT.

Falla de multiples nodos (2+ de 4):

1. El consenso BFT se detiene (quorum no alcanzado).
2. Activacion del Comité de Crisis.
3. Reconstruccion de nodos desde imagen verificada.
4. Restauracion de estado desde el ultimo checkpoint o nodo sobreviviente.
5. Re-establecimiento del quorum BFT.
6. Verificacion de integridad completa antes de reanudar servicios.

Falla de almacenamiento persistente:

1. Restaurar volumen desde snapshot de Fly.io o checkpoint de RocksDB.
2. Si el snapshot no esta disponible, restaurar desde exportacion off-site.
3. Sincronizar estado faltante desde peers BFT.
4. Verificar integridad de cadena de auditoria y monotonica de seriales.

6.5.4 Procedimiento de recuperacion

1. Verificar que todos los nodos ejecutan la misma version de software.
2. Ejecutar sincronizacion de estado BFT.
3. Verificar cadena de auditoria: `verify_audit_chain()`.
4. Verificar serial TSA > ultimo serial conocido.
5. Verificar NTP sync: `NtpTimeSource::validate()`.
6. Publicar CRL fresca.
7. Verificar OCSP con certificados conocidos.
8. Reanudar servicios en orden: OCSP, CRL, API Gateway, TSA, Registro de auditoria, CA, RA.

6.5.5 Verificacion y retorno a operacion normal

- 4 nodos BFT operativos y en consenso.
- Todos los health checks responden 200.
- Cadena de auditoria integra.
- TSA emite sellos con serial monotonicamente creciente.
- CRL publicada y accesible.
- OCSP responde correctamente.

RTO: Nodo individual: < 1 minuto (consenso continua). Multiples nodos: 4 horas.
Almacenamiento: 4 horas. **RPO:** 0 (estado replicado en nodos BFT).

6.6 Desastre natural o perdida de datacenter

Referencia PS01: R-21 (terremoto), R-22 (incendio), R-33 (inundacion), R-31 (corte electrico prolongado).

6.6.1 Descripcion y disparadores

Evento que causa la indisponibilidad total de la region primaria de Fly.io (IAD) o la destruccion fisica de la infraestructura. Incluye: terremoto, incendio, inundacion, corte electrico prolongado, falla masiva del proveedor cloud.

Disparadores:

- Todos los nodos BFT inalcanzables desde monitoreo externo.
- Fly.io reporta indisponibilidad de region completa.
- Confirmacion de evento catastrofico por medios publicos.

6.6.2 Deteccion

- Monitoreo externo (independiente de Fly.io) detecta indisponibilidad total.
- Alertas de DNS failure para todos los endpoints del PSC.
- Pagina de estado de Fly.io confirma indisponibilidad de region.

6.6.3 Procedimiento de respuesta

1. Activacion del Comite de Crisis.
2. Evaluacion del alcance: region temporal vs. destruccion permanente.
3. Comunicacion a suscriptores y partes confiantes (pagina de estado en dominio alternativo).
4. Notificacion a la EA dentro de 24 horas.

6.6.4 Procedimiento de recuperacion

1. Despliegue de infraestructura en region alternativa de Fly.io (ORD, SJC o EWR).
2. Restauracion de estado desde:
 - Ultimo checkpoint off-site (exportacion diaria cifrada).
 - Si disponible: sincronizacion desde nodo sobreviviente en otra region.
3. Reconstruccion de 4 nodos BFT en la nueva region.
4. Carga de clave intermedia CA desde boveda offline.
5. Verificacion completa: cadena de auditoria, seriales TSA, estado de certificados.
6. Publicacion de CRL fresca.
7. Actualizacion de DNS para apuntar a la nueva region.
8. Reanudar servicios en orden de prioridad.

6.6.5 Verificacion y retorno a operacion normal

- 4 nodos BFT operativos en nueva region.
- DNS resuelve correctamente a los nuevos endpoints.
- OCSP y CRL accesibles desde suscriptores y partes confiantes.
- TSA emite sellos con serial correcto y NTP validado.
- Cadena de auditoria integra desde genesis.
- Informe a la EA con cronologia y acciones tomadas.

RTO: 4 horas (activacion de sitio secundario pre-configurado) a 24 horas (reconstruccion completa). **RPO:** Ultimo checkpoint off-site (< 24 horas, tipicamente < 1 hora).

6.7 Ataque cuantico (harvest-now-decrypt-later)

Referencia PS01: R-10 (harvest-now-decrypt-later sobre FES), R-11 (ruptura de Ed25519 por computador cuantico), R-12 (fallo en transicion cripto FES a FEA), R-13 (vulnerabilidad en implementacion ML-DSA-65).

6.7.1 Descripcion y disparadores

Deteccion de que un adversario esta recolectando comunicaciones cifradas o firmadas con algoritmos clasicos (Ed25519/FES) para descifrarlas cuando disponga de un computador cuantico criptograficamente relevante (CRQC). Tambien cubre la publicacion de un ataque que reduce la seguridad de ML-DSA-65 o Ed25519 por debajo de niveles aceptables.

Disparadores:

- Publicacion de paper academico que reduce la seguridad de Ed25519 o ML-DSA-65 significativamente.
- Anuncio de NIST sobre deprecacion de algoritmo en uso.
- Inteligencia de amenazas sobre actor estatal con capacidad CRQC.
- Deteccion de trafico anomalo de recoleccion contra endpoints del PSC.

6.7.2 Deteccion

- Monitoreo de publicaciones de NIST, ETSI y comunidad criptografica.
- Analisis de trafico: patrones de captura exhaustiva de comunicaciones P2P o respuestas OCSP.
- Alertas del sistema de Algorithm Death Day (simulacion de amenaza cuantica de 22 tests en 7 fases).

6.7.3 Procedimiento de respuesta

1. Evaluacion de la amenaza por el Arquitecto Criptografico:
 - Clasificar si afecta FES (Ed25519), FEA (ML-DSA-65) o ambos.
 - Estimar la linea de tiempo de la amenaza (inmediata vs. futura).
 - Determinar si los niveles de seguridad cuantica actuales son suficientes (ML-DSA-65 = 143-bit quantum security).
2. Si la amenaza es inmediata contra Ed25519 (FES):
 - Activar plan de migracion acelerada de FES a FEA (ML-DSA-65 ya implementado).
 - Notificar a suscriptores con certificados FES para re-emision con FEA.
 - Marcar certificados FES como no recomendados en politica.
3. Si la amenaza es contra ML-DSA-65:
 - Evaluar algoritmos PQC alternativos (ML-KEM, SLH-DSA).
 - Planificar migracion de emergencia segun la linea de tiempo de la amenaza.
 - Notificacion a la EA sobre cambio de algoritmo planificado.

6.7.4 Procedimiento de recuperacion

1. Despliegue de nuevo algoritmo de firma en nodos BFT.
2. Generacion de nueva clave CA con nuevo algoritmo (ceremonia M-of-N).
3. Re-emision de certificados afectados con nuevo algoritmo.

4. Publicacion de nueva CRL firmada con nuevo algoritmo.
5. Actualizacion de CPS con nuevo algoritmo.
6. Verificacion de compatibilidad con partes confiantes.

6.7.5 Verificacion y retorno a operacion normal

- Todos los servicios operan con el nuevo algoritmo.
- Certificados criticos re-emitidos.
- CPS actualizado y publicado.
- Suscriptores notificados y certificados renovados.
- Informe a la EA con analisis de impacto y acciones tomadas.

RTO: Variable. Amenaza futura: semanas/meses. Amenaza inmediata contra FES: 48 horas (migracion a ML-DSA-65 ya disponible). **RPO:** N/A.

7. Preservacion de Evidencia

7.1 Objetivo

Garantizar que la evidencia digital generada por los servicios del PSC y durante la gestion de incidentes mantenga su integridad, autenticidad y admisibilidad ante tribunales conforme la Ley 19.799 Art. 5 y elCodigo de Procedimiento Civil.

7.2 Cadena de custodia

Toda evidencia digital recolectada durante un incidente debe mantener una cadena de custodia documentada:

Paso	Accion	Responsable	Registro
1	Identificacion de la evidencia (logs, estado de nodo, configuracion, memoria)	Lider Tecnico	Formulario de identificacion de evidencia
2	Adquisicion: copia forense bit-a-bit del medio o exportacion de logs con hash	Administrador Sistemas	Hash SHA-256 de la evidencia adquirida
3	Sello de tiempo: aplicar sello TSA a cada pieza de evidencia (si TSA disponible) o registrar hora NTP verificada	Operador PKI	Sello TSA o registro temporal
4	Almacenamiento: deposito en	Oficial de Seguridad	

Paso	Accion	Responsable	Registro
	contenedor cifrado con acceso restringido		Registro de acceso al contenedor
5	Transferencia: documentar cada transferencia de custodia entre personas	Receptor	Acta de transferencia firmada
6	Disposicion: retencion minima de 7 anos; destruccion solo con autorizacion de la EA	Oficial de Seguridad	Acta de destruccion (si aplica)

7.3 Integridad de la evidencia

- Cada pieza de evidencia se identifica con un hash SHA-256 calculado al momento de la adquisicion.
- Los hashes se registran en la cadena de auditoria del PSC (append-only, tamper-evident).
- Si el TSA esta operativo, cada pieza de evidencia recibe un sello de tiempo RFC 3161.
- Las copias forenses se almacenan en medio write-once o con control de integridad.
- La cadena de hash de auditoria del PSC constituye en si misma evidencia probatoria de todas las operaciones realizadas.

7.4 Admisibilidad judicial (Ley 19.799 Art. 5)

Para cumplir con los requisitos de admisibilidad del documento electronico como medio de prueba:

- Los registros de auditoria estan firmados electronicamente (cadena de hash ligada a clave del PSC).
- Los sellos de tiempo proporcionan fecha cierta conforme Ley 19.799.
- La integridad de los registros es verificable por terceros mediante `verify_audit_chain()` y validacion de sellos TSA.
- Los procedimientos de adquisicion de evidencia estan documentados y son reproducibles.
- Se preserva la metadata asociada: timestamp, origen, operador, trace ID.

7.5 Retencion

Tipo de evidencia	Retencion minima	Justificacion
Registros de auditoria del PSC	7 anos	DS 181, ETSI TS 102 042
	10 anos	

Tipo de evidencia	Retencion minima	Justificacion
Evidencia de incidentes de seguridad		Prescripcion de delitos informaticos (Ley 21.459)
Actas de ceremonia de clave	Permanente	Trazabilidad de ciclo de vida de CA
Registros de emision y revocacion	7 anos	DS 181

8. Instalaciones Alternativas

8.1 Capacidad del sitio secundario

El sitio secundario debe cumplir con los mismos requisitos de servicio que el sitio primario para los servicios de prioridad 1 y 2 (seccion 4.5). Conforme ISO 27002:2022 A.8.14 (redundancia de instalaciones de procesamiento de informacion):

Requisito	Sitio primario (IAD)	Sitio secundario
Nodos BFT	4 nodos (goya-node, goya-node-2, goya-node-3, goya-node-4)	4 nodos (capacidad identica)
Almacenamiento RocksDB	Volumenes persistentes Fly.io	Volumenes persistentes en region alternativa
Conectividad de red	Anycast Fly.io	Anycast Fly.io (region alternativa)
Capacidad de computo	Suficiente para BFT + todos los servicios	Identica al primario
Acceso a claves	Clave intermedia CA en memoria de nodo	Clave intermedia CA restaurable desde boveda offline
NTP	Multiples fuentes NTP	Multiples fuentes NTP
DNS	Fly.io managed DNS	Failover DNS automatico

8.2 Procedimiento de failover

1. Monitoreo externo confirma indisponibilidad del sitio primario (> 15 minutos para servicios criticos).
2. Coordinador de Crisis autoriza activacion de sitio secundario.
3. Despliegue de aplicacion en region alternativa de Fly.io (si no esta pre-desplegada).
4. Restauracion de ultimo estado desde checkpoint off-site.
5. Carga de clave intermedia CA desde boveda offline (requiere ceremonia de doble custodia).
6. Verificacion de integridad: cadena de auditoria, seriales, NTP.
7. Actualizacion de DNS: cambio de registros A/AAAA a nuevas IPs.

8. Verificación de accesibilidad desde clientes de prueba.
9. Reanudación de servicios en orden de prioridad.

8.3 Failback a sitio primario

Una vez que el sitio primario está disponible nuevamente:

1. Verificación de integridad de la infraestructura del sitio primario.
2. Sincronización de estado desde el sitio secundario (activo) al primario.
3. Verificación de integridad en el primario: cadena de auditoría, estado de certificados, seriales TSA.
4. Failover controlado: redirección gradual de tráfico al primario.
5. Verificación de operación normal en el primario durante 24 horas.
6. Desactivación del sitio secundario a modo standby.

9. Plan de Pruebas

9.1 Tipos de pruebas

Tipo	Descripción	Participantes
Ejercicio de mesa (tabletop)	Revisión del plan por el Comité de Crisis sin ejecución real; discusión de escenarios y decisiones	Comité de Crisis completo
Recorrido (walkthrough)	Ejecución paso a paso de procedimientos específicos en entorno de prueba	Equipo técnico involucrado en el procedimiento
Simulación	Ejecución de un escenario realista en entorno aislado con interrupción controlada	Comité de Crisis + equipo técnico
Prueba completa (full DR)	Reconstrucción total desde respaldos en sitio alternativo	Todo el personal con rol en el plan

9.2 Calendario de pruebas

Prueba	Frecuencia	Escenario
Restauración de checkpoint RocksDB	Mensual	Restaurar snapshot, verificar estado e integridad de cadena de auditoría
Verificación de cadena de auditoría	Semanal (automatizada)	<code>verify_audit_chain()</code> en log de producción
Ejercicio de mesa	Trimestral	Rotación entre los 7 escenarios de la sección 6
Failover a sitio secundario	Semestral	Simular falla de sitio primario, activar

Prueba	Frecuencia	Escenario
Reconstruccion de clave CA (M-of-N)	Anual	secundario, verificar servicios Ensamblar fragmentos en entorno de prueba, verificar clave contra hash conocido
Prueba completa de DR	Anual	Reconstruccion total desde respaldos en region alternativa
Prueba de compromiso de clave	Anual	Simulacion de escenario 6.3: revocacion, re-emision, notificaciones

9.3 Criterios de exito

Cada prueba se evalua contra los siguientes criterios:

Criterio	Metrica	Umbral de exito
Tiempo de recuperacion	Tiempo medido vs. RTO declarado	Tiempo medido $\leq$ RTO
Integridad de datos	<code>verify_audit_chain()</code> post-restauracion	Sin errores
Compleitud del servicio	Servicios restaurados / servicios requeridos	100%
Precision de notificaciones	Notificaciones emitidas vs. plan de comunicacion	100% de destinatarios cubiertos
Monotonicia TSA	Serial TSA post-recuperacion $>$ ultimo serial conocido	Cumple
Validez de certificados	Certificado de prueba emitido y validado por OCSP	Valido
Participacion	Personal convocado vs. personal presente	$\geq$ 80%

9.4 Documentacion de resultados

Cada prueba genera un informe que contiene:

- Fecha, hora y duracion de la prueba.
- Escenario ejecutado (referencia a seccion 6).
- Participantes.
- Resultados contra cada criterio de exito (seccion 9.3).
- Desviaciones detectadas y acciones correctivas.
- Recomendaciones de mejora al plan.
- Firma del Coordinador de Crisis.

Los informes se retienen por 7 anos como parte del registro de auditoria del PSC.

10. Revision y Mantencion

10.1 Revision periodica

Este plan se revisa como minimo una vez al ano. La revision incluye:

- Verificacion de que los RTO/RPO siguen siendo apropiados para los niveles de riesgo actuales (PS01).
- Actualizacion de contactos, roles y responsabilidades.
- Incorporacion de lecciones aprendidas de pruebas e incidentes reales.
- Revision de dependencias externas (proveedores, algoritmos, regulaciones).
- Validacion de que los respaldos y procedimientos de recuperacion son funcionales.

10.2 Eventos que disparan revision extraordinaria

Evento	Plazo de revision
Incidente real que active un escenario de este plan	30 dias tras cierre del incidente
Cambio significativo en la infraestructura (nueva region, nuevo proveedor)	Antes de la entrada en produccion
Actualizacion de PS01 (nuevos riesgos o cambios de nivel)	30 dias tras la actualizacion
Cambio en normativa aplicable (Ley 19.799, DS 181, EA-103)	60 dias tras la publicacion
Resultado insatisfactorio en prueba de continuidad (seccion 9)	15 dias tras la prueba
Cambio de algoritmo criptografico en produccion	Antes del despliegue
Cambio en la estructura organizacional del PSC	30 dias tras el cambio

10.3 Proceso de revision

1. El Coordinador de Crisis convoca la revision con 15 dias de anticipacion.
2. Cada responsable de escenario (seccion 6) revisa y actualiza su procedimiento.

3. El Lider Tecnico verifica la vigencia de procedimientos tecnicos (scripts, endpoints, credenciales).
4. El Oficial de Seguridad verifica la coherencia con PS01 y PS02 actualizados.
5. El Comite de Crisis aprueba la version actualizada.
6. La nueva version se distribuye a todos los receptores (seccion 1.2).
7. Se actualiza la version y fecha del documento.

11. Coherencia con PS01

11.1 Mapeo de riesgos PS01 a escenarios BCP

ID Riesgo PS01	Descripcion del riesgo	Nivel PS01	Escenario BCP	Justificacion de RTO/RPO
R-01	Robo de clave privada CA raiz	Bajo	6.3	RTO 24h: clave offline requiere ceremonia M-of-N; bajo probabilidad pero impacto critico
R-02	Robo de clave privada CA intermedia	Medio	6.3	RTO 24h: revocacion y re-emision necesarias
R-03	Intrusion a nodos BFT	Medio	6.2	RTO 4-24h: reconstruccion de nodo desde imagen limpia
R-04	DDoS contra API Gateway	Medio	6.2	RTO 1h: mitigacion en capa de red
R-10	Harvest-now-decrypt-later sobre FES	Medio	6.7	RTO variable: migracion planificada a FEA
R-11	Ruptura de Ed25519 por computador cuantico	Bajo	6.7	RTO 48h: ML-DSA-65 ya implementado como alternativa
R-12	Fallo en transicion cripto FES a FEA	Medio	6.1, 6.7	RTO 4h: rollback a version anterior
R-13	Vulnerabilidad en implementacion ML-DSA-65	Medio	6.7	RTO variable: depende de la severidad
R-14	Phishing contra operador PKI	Medio	6.2	RTO 4h: rotacion de credenciales
R-16	Corrupcion de RocksDB	Medio	6.4, 6.5	RTO 4h: restauracion desde checkpoint o peer
R-18		Medio	6.1	

ID Riesgo PS01	Descripcion del riesgo	Nivel PS01	Escenario BCP	Justificacion de RTO/RPO
	Despliegue de codigo con errores			RTO 4h: rollback inmediato a version anterior
R-19	Eliminacion accidental de registros de auditoria	Medio	6.4	RTO 4h/RPO 0: cadena de hash no tolera gaps
R-21	Terremoto en datacenter	Medio	6.6	RTO 4-24h: failover a region alternativa
R-22	Incendio en instalaciones	Medio	6.6	RTO 4-24h: failover a region alternativa
R-26	Exfiltracion de datos por personal	Medio	6.2	RTO 4h: aislamiento y reconstruccion
R-30	Agotamiento de almacenamiento	Medio	6.4	RTO 4h: expansion de volumen
R-31	Corte electrico prolongado	Bajo	6.6	RTO 4h: cloud provider maneja redundancia electrica
R-32	Bug en logica de consenso o firma	Medio	6.1	RTO 4h: rollback de despliegue
R-33	Inundacion en datacenter	Bajo	6.6	RTO 4-24h: failover a region alternativa

11.2 Justificacion de prioridades

Los RTO se asignan siguiendo la logica:

- **RTO <= 15 min:** Servicios de prioridad 1 (OCSP, CRL, API Gateway) donde la interrupcion impacta directamente la validez juridica de operaciones de firma en curso. Justificado por el impacto legal critico (seccion 4.2) y la disponibilidad de redundancia automatica (BFT, stateless services).
- **RTO <= 4 horas:** Servicios de prioridad 2 (TSA, Registro de auditoria) y escenarios de falla parcial (nodo individual, corrupcion de datos, software). Justificado por el impacto alto pero no inmediato; permite tiempo para diagnostico y restauracion controlada.
- **RTO <= 24 horas:** Servicios de prioridad 3 (CA emision) y escenarios de alta complejidad (compromiso de clave, desastre regional). Justificado por la complejidad de los procedimientos de recuperacion (ceremonia M-of-N, reconstruccion de infraestructura completa).
- **RTO <= 48 horas:** Servicios de prioridad 4 (RA verificacion). Justificado por la naturaleza inherentemente asincrona del proceso de verificacion de identidad.

12. Referencias

Referencia	Titulo
ISO 22301:2019	Security and resilience – Business continuity management systems – Requirements
ISO/IEC 27002:2022	Information security, cybersecurity and privacy protection – Information security controls
ETSI TS 102 042 v2.4.1	Policy requirements for certification authorities issuing qualified certificates
ETSI EN 319 401 v2.3.1	General policy requirements for trust service providers
Ley 19.799	Sobre documentos electronicos, firma electronica y servicios de certificacion de dicha firma
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma tecnica para la firma electronica avanzada
Ley 21.459	Establece normas sobre delitos informaticos
Ley 19.628	Sobre proteccion de la vida privada
EA-103 v2.1	Guia de acreditacion de prestadores de servicios de certificacion
GOYA-PS01-001	Plan de Gestion de Riesgos y Amenazas
GOYA-PS02-001	Politica de Seguridad de la Informacion
GOYA-CPS-001	Certification Practice Statement
GOYA-IRP-001	Plan de Respuesta a Incidentes
NIST SP 800-34 Rev.1	Contingency Planning Guide for Federal Information Systems
NIST FIPS 204	Module-Lattice-Based Digital Signature Standard (ML-DSA)